Guion de presentación y demostración de R-CONF

Efrain Retana Segura · EIF402 Administración de Bases de Datos · II Ciclo 2026. Duración sugerida: 8 a 10 minutos. Este guion orienta una explicación con palabras propias; cada resultado mostrado debe corresponder a una ejecución conservada por el estudiante. Faro Servicios S.A. es una empresa ficticia y el estado «antes» es una hipótesis de riesgo, no una medición histórica.

Preparación antes de presentar

1. Abrir `http://127.0.0.1:8000/#overview` y confirmar que el encabezado indique **Oracle**, no modo demostración. Si el servidor está apagado, iniciarlo desde la carpeta del proyecto con `./start-local.ps1` en PowerShell. Si aparece «sin sesión», usar **Conectar sesión** con el token del rol pertinente; no mostrarlo ni decirlo en voz alta.
2. Tener abierto el riesgo registrado y su referencia **EV-001**. Verificar antes de exponer que la referencia describe una prueba real y apunta al archivo o acta original. Si la sesión actual no muestra el riesgo, no presentar el contador vacío como si la base estuviera vacía: conectarse o explicar la limitación.
3. Preparar por separado las salidas originales de `05_verify_runtime.sql` y `04_verify_dba.sql`, el PDF `07_evidencia_oracle_2026-10-26.pdf` y el PDF `04_uso_ia.pdf`. Ocultar contraseñas, tokens, cadenas de conexión sensibles y cualquier dato personal.
4. Comprobar que los datos de ejemplo son sintéticos. No ejecutar de nuevo scripts de instalación (`01_accounts.sql` y `02_schema.sql`) para la presentación: son de primera instalación. Para repetir pruebas, usar únicamente scripts de verificación con la cuenta indicada.

1. Apertura y problema (45 segundos)

Pantalla: Vista general y Caso de estudio. **Decir:** «R-CONF es un laboratorio para evaluar riesgos de confidencialidad de bases de datos Oracle 21c XE, usando ISO/IEC 27001 y 27002 de 2022, el ciclo PHVA y mínimo privilegio. El caso Faro Servicios S.A. es ficticio; las pruebas SQL proceden de mi PDB XEPDB1». Señalar el alcance: información sintética, una cuenta de aplicación y acceso a tablas sensibles. No llamarlo auditoría certificada.

2. Riesgo y decisión de tratamiento (60 segundos)

Pantalla: Registro de riesgos. Abrir el riesgo creado y mostrar activo, amenaza, probabilidad, impacto, responsable, tratamiento y selector de controles. **Decir:** «Si la aplicación recibe acceso directo a tablas base, una credencial comprometida expone más datos. Registré el riesgo, estimé exposición inherente y propuse limitar lectura mediante vistas y escritura mediante un paquete». Mostrar los controles 5.18, 8.2 y 8.3 si corresponden al registro real; no modificarlo solo para que coincida con el guion. Explicar que el residual es una estimación sujeta a revisión.

3. Ciclo PHVA y EV-001 (60 segundos)

Pantalla: Ciclo PHVA y Expediente de evidencias. **Decir:** «Planificar identifica y prioriza; Hacer aplica las restricciones; Verificar contrasta lo esperado con Oracle; Actuar corrige y documenta la decisión residual». Mostrar la referencia EV-001 y explicar exactamente a qué archivo, prueba, fecha y ejecutor remite. Una referencia escrita por sí sola no prueba que el control funcionó. Si el sistema permitió avanzar de Planificar a Hacer sin evidencia, describir la regla real de la aplicación y reservar la exigencia de prueba para Verificar y para la aprobación residual; no afirmar una validación automática inexistente.

4. Controles visibles y prueba positiva/negativa (90 segundos)

Pantalla: Mínimo privilegio y Caso de estudio. Comparar la hipótesis inicial con el estado probado. Luego mostrar en la salida original de `05_verify_runtime.sql` que `RCONF_APP` leyó `RCONF_OWNER.MASKED_PERSONAL` con correo `[oculto]`, mientras el `SELECT` directo de `RCONF_OWNER.DEMO_PERSONAL` devolvió `ORA-00942`. Mostrar que `RISK_VIEW` fue legible y que `SELECT` y `UPDATE` directos de `RISKS` fueron denegados. **Decir:** «Una prueba positiva demuestra la función permitida; una negativa comprueba la restricción». La salida aportada apoya T07 y T08 preliminarmente; falta revisión independiente de archivos originales.

5. Auditoría y hallazgo abierto (75 segundos)

Pantalla: Expediente de evidencias, T11. Mostrar en `04_verify_dba.sql` la política `RCONF_ACCESS_POLICY` habilitada y las filas relevantes del rastro. **Decir:** «La política está activa, pero una fila de `DEMO_PERSONAL` tiene código 0 y otra 2004. La prueba negativa en SQL*Plus devolvió ORA-00942. Debo correlacionar hora, sesión y sentencia antes de cerrar T11». No equiparar automáticamente 2004 con ORA-00942 y no ocultar la fila de código 0. Un auditor debe poder reproducir la conclusión.

6. Comparación ISO 2013 y 2022 (90 segundos)

Pantalla: 2013 vs. 2022. **Decir:** «ISO/IEC 27001 fija requisitos del sistema de gestión; ISO/IEC 27002 orienta la selección e implementación de controles. La edición 2022 reorganizó el catálogo de 27002: de 114 controles en 14 dominios a 93 en cuatro grupos, con once controles nuevos y atributos para clasificarlos. No implica que se hayan eliminado sin más 21 salvaguardas: hubo fusiones y correspondencias». Mostrar al menos dos mapeos pertinentes al caso y explicar por qué la tabla del sitio es una selección académica, no la norma completa. Mencionar en 27001:2022 la planificación de cambios y la mayor claridad sobre procesos e interacciones. Las fuentes oficiales figuran enlazadas en el sitio.

7. Uso de IA, límites y cierre (60 segundos)

Pantalla: Documentación y PDF `04_uso_ia.pdf`. **Decir:** «La herramienta asistió en borradores de interfaz, código y documentación; el estudiante aportó el alcance, instaló Oracle, ejecutó scripts y compartió las salidas. La declaración separa lo observado de lo pendiente y debe completarse con evidencias verificables de autoría». Mostrar luego la lista de cierre: correlacionar T11, revisar EV-001, ejecutar la comprobación final del propietario instalador y validar identidad, secretos y conexión cifrada antes de Azure con datos reales. Azure está preparado como plan, sin publicación realizada.

Si el docente pide una prueba en vivo

- **Ver el riesgo guardado:** conectarse en la web con un rol autorizado, abrir Registro de riesgos y buscar el identificador. Mostrar EV-001 y su archivo fuente. No crear datos ficticios como evidencia de producción.
- **Repetir la prueba de mínimo privilegio:** abrir SQL*Plus, conectar `RCONF_APP` a `localhost:1521/XEPDB1` sin exponer la contraseña y ejecutar `@C:\Users\Usuario\Documents\Codex\2026-10-25\q\outputs\rconf-oracle\sql\05_verify_runtime.sql`. Antes de interpretar, confirmar `RCONF_APP` y `XEPDB1` en la salida. Es esperable ver `ORA-00942` en las pruebas negativas; cualquier éxito inesperado invalida el control.
- **Revisar auditoría:** en otra sesión DBA de XEPDB1 ejecutar `@C:\Users\Usuario\Documents\Codex\2026-10-25\q\outputs\rconf-oracle\sql\04_verify_dba.sql`. Conservar la salida con hora y cuenta, y explicar T11 como pendiente hasta correlacionar eventos.
- **Si falla la conexión web:** comprobar `/api/config`, que debe indicar `oracle`, confirmar servidor y `.env` local, y reiniciar el servidor tras cambiar configuración. Nunca proyectar el contenido de `.env`.

Mensaje final sugerido

«Puedo demostrar lecturas permitidas por vistas y denegaciones de tablas base en Oracle. El registro PHVA organiza tratamiento y evidencia. El hallazgo de auditoría T11 queda abierto y documentado; el proyecto no reclama certificación ni un despliegue Azure ya realizado». Ensayar con las salidas propias, controlar el tiempo y dejar uno o dos minutos para preguntas.

Referencias del documento

S1. ISO. ISO/IEC 27001:2022. Ficha oficial de requisitos del SGSI. https://www.iso.org/standard/27001

S2. ISO. ISO/IEC 27002:2022. Ficha oficial de orientación de controles. https://www.iso.org/standard/75652.html

S8. Oracle. Database Security Guide, Configuring Privilege and Role Authorization. Fundamento de roles y permisos de objetos. https://docs.oracle.com/en/database/oracle/oracle-database/19/dbseg/configuring-privilege-and-role-authorization.html

S9. Oracle. SQL Language Reference, CREATE AUDIT POLICY Unified Auditing. Referencia de sintaxis; verificar ejecución en 21c XE. https://docs.oracle.com/en/database/oracle/oracle-database/19/sqlrf/CREATE-AUDIT-POLICY-Unified-Auditing.html

S15. ISO/IEC JTC 1/SC 27. Revista del subcomité, artículo de los editores de ISO/IEC 27002:2022 sobre estructura, 93 controles, cinco atributos y anexos A/B. https://committee.iso.org/files/live/sites/jtc1sc27/files/resources/ISO-IEC%20JTC%201-SC%2027_N22755_SC27%20Journal%20Vol%202%20Issue%202%20(update%20Dec%202022).pdf